

INFORME DE INCIDENTE DE SEGURIDAD

SQL Injection en DVWA

ISO 27001

Autor: Alvaro Chagas

Fecha: 09/06/2026

1. Introducción

En este informe voy a documentar una vulnerabilidad de inyección SQL que encontré en la aplicación DVWA (Damn Vulnerable Web Application). La prueba la hice en una máquina virtual con Debian instalada en VirtualBox, con un stack LAMP (Apache, MariaDB y PHP). Todo fue hecho en un entorno controlado con fines educativos.

2. Descripción del incidente

La vulnerabilidad fue encontrada en el módulo "SQL Injection" de DVWA. El nivel de seguridad estaba en "Low". El problema es que la aplicación no valida lo que el usuario escribe en el campo de entrada, lo que permite inyectar código SQL directamente en la consulta de la base de datos.

- Tipo: SQL Injection
- Módulo: SQL Injection (DVWA)
- Nivel de seguridad: Low
- Sistema: DVWA con LAMP en Debian
- Impacto: alto, se pueden ver datos de todos los usuarios

3. Como reproduce el ataque

1. Abri el navegador en la VM y fui a <http://localhost/DVWA>

2. Inicie sesion con:

usuario: admin

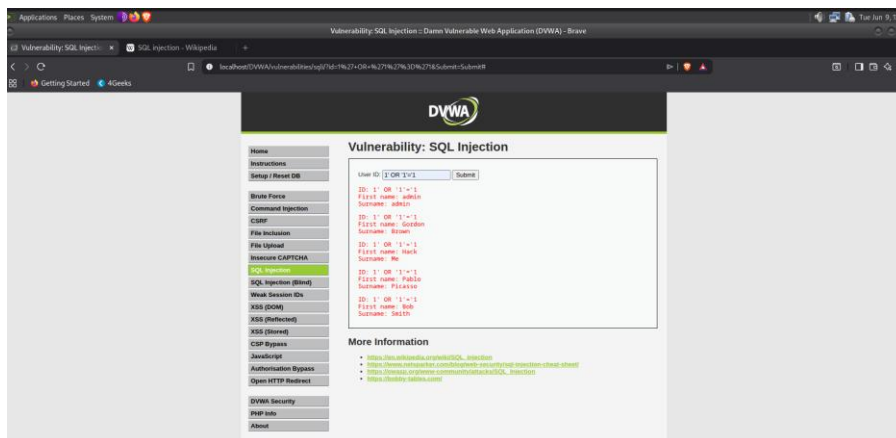
contraseña: password

3. Fui a "DVWA Security" y puse el nivel en "Low"

4. Entre al módulo "SQL Injection" y en el campo User ID escribi:

`1' OR '1'='1`

5. Le di a Submit y aparecieron todos los usuarios de la base de datos,
lo que confirma que el ataque funciono.



4. Impacto

Con este ataque se puede:

- Ver todos los usuarios y sus datos guardados en la base de datos
- Potencialmente modificar o borrar información si se usan otros payloads
- Comprometer la confidencialidad de la información almacenada

Es una vulnerabilidad bastante grave porque con una sola línea en el campo de búsqueda ya se pueden ver todos los registros sin necesidad de saber ninguna contraseña.

5. Recomendaciones

Para evitar este tipo de vulnerabilidad se recomienda:

1. Usar consultas parametrizadas (prepared statements) en lugar de armar las consultas SQL con los datos del usuario directamente.
2. Validar y filtrar los datos que ingresa el usuario antes de usarlos en una consulta.
3. No usar el usuario root de la base de datos para la aplicación web, usar uno con los permisos mínimos necesarios.
4. Hacer pruebas de seguridad periódicas para detectar este tipo de vulnerabilidades antes de que alguien las explote.

6. Conclusión

La inyección SQL es una vulnerabilidad muy conocida pero que todavía aparece en muchas aplicaciones. En este caso fue fácil de explotar porque no había ninguna validación en el campo de entrada. Con solo escribir una condición siempre verdadera se pudieron ver todos los datos de la base de datos.

Esto muestra lo importante que es validar siempre los datos que ingresa el usuario y no confiar en que va a escribir solo lo esperado.